

SIMATS ENGINEERING

ASSESSMENT TOOL 1- Enumeration Analysis

COURSE CODE: ITA14

COURSE NAME: Ethical Hacking

COURSE OUTCOME COVERED

CO3: *Analyse network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities. (BL3)*

Assessment Tool Weightage: 40%

QUESTIONS: 5

Total Marks:100

1. A cyber security consulting company has been contracted to perform an initial security assessment of the publicly accessible server **scanme.nmap.org**. Before conducting any vulnerability assessment, the client requires a detailed enumeration report. Using **Nmap**, perform host discovery, TCP port scanning, service version detection, operating system fingerprinting, and default script scanning on **scanme.nmap.org**. Analyze all identified ports and services, determine their business purpose, and evaluate whether they are necessary for public access. Discuss how a threat actor could utilize the information gathered during enumeration to launch further attacks such as service exploitation, brute-force attacks, or vulnerability discovery. Prepare a technical report summarizing your findings, attack surface analysis, risk assessment, and recommendations for securing the server.
2. The security team has deployed a deliberately vulnerable Linux server, **192.168.56.101 (Metasploitable 2)**, in an isolated laboratory environment to train penetration testers. As part of the pre-engagement reconnaissance phase, use **Nmap** to perform comprehensive enumeration of **192.168.56.101**. Identify all open ports, running services, service versions, and operating system information. Analyze the purpose of each service and determine which services could provide potential entry points for an attacker. Categorize the discovered services into High, Medium, and Low risk levels based on their exposure and functionality. Explain how the enumeration results could guide a penetration tester in selecting potential attack vectors and exploitation strategies.
3. A financial organization wants to assess the security posture of a Windows workstation located at **192.168.56.102** before connecting it to the production network. Using **Nmap**, enumerate **192.168.56.102** to identify active ports, network services, file-sharing protocols, remote management services, and operating system details. Analyze whether the discovered services comply with the principle of least privilege and identify any services that may unnecessarily increase the attack surface. Discuss how an attacker could leverage the identified services for reconnaissance, lateral movement, or unauthorized access. Based on your findings, propose a set of security hardening measures to improve the system's resilience against cyberattacks.

CO3 – ASSESSMENT TOOL 1

ENUMERATION ANALYSIS – DETAILED ANSWERS

Student Name: K Nitheesh Kumar

Register Number: 192325090

Course: Ethical Hacking | Course Code: ITA14

Course Outcome: CO3 – Analyse network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities. 穀filecite學turn3file0學L5-L9係

Important assessment note: The supplied document asks for Nmap enumeration of a public training host and three intentionally isolated laboratory targets. The report below explains the methodology and gives expected/representative analysis where the PDF itself does not contain scan output. Actual scan results should be replaced with the student's captured laboratory evidence before submission. The document's questions are on page 1 and page 2 of the supplied PDF. 穀filecite學turn3file0學L10-L34係 穀filecite學turn3file0學L37-L55係

QUESTION 1 – ENUMERATION OF scanme.nmap.org

1.1 Objective and Scope

The objective is to perform an initial enumeration of the authorized training host scanme.nmap.org before vulnerability assessment. The supplied question specifically requires host discovery, TCP port scanning, service-version detection, operating-system fingerprinting and default-script scanning. It also requires analysis of the business purpose of identified services, evaluation of whether they are necessary for public access, threat-actor use of enumeration information, risk assessment and security recommendations. 穀filecite學turn3file0學L10-L18係

1.2 Host Discovery

Host discovery determines whether the target is reachable before detailed scanning. Because scanme.nmap.org is a purpose-built Nmap training target, the assessment should remain within the host's stated testing purpose and should not be extended to unrelated systems.

```
nmap -sn scanme.nmap.org
ping -c 4 scanme.nmap.org
```

The Nmap -sn option performs host discovery without a normal port scan. Ping provides a basic reachability check, but a lack of ICMP response does not necessarily prove that the host is unavailable because firewalls may filter ICMP.

1.3 TCP Port Scanning

```
nmap -sS scanme.nmap.org
nmap -p- --min-rate 1000 scanme.nmap.org
```

A SYN scan identifies TCP ports that appear open, closed or filtered. A full TCP port range scan can provide broader coverage than the default Nmap port list. In an academic report, the exact date/time and command used should be recorded because public training hosts can change over time.

1.4 Service and Version Detection

```
nmap -sV scanme.nmap.org
```

Version detection attempts to determine the application protocol and software/version associated with each open port. This information is important because vulnerability research depends heavily on knowing which service implementation is actually exposed.

1.5 Operating-System Fingerprinting

```
sudo nmap -O scanme.nmap.org
```

Nmap OS detection uses network responses to estimate the target operating system and characteristics. Results should be described as an inference rather than an absolute fact. Firewalls, virtual machines and unusual network paths can reduce fingerprinting accuracy.

1.6 Default Script Scanning

```
nmap -sC scanme.nmap.org
```

```
nmap -sC -sV scanme.nmap.org
```

The default Nmap script set can collect additional service information and identify common configuration details. It is useful after basic port discovery because scripts can provide context about protocols and service behavior.

1.7 Combined Enumeration Command

```
sudo nmap -sS -sV -O -sC scanme.nmap.org -oN scanme_enum.txt
```

The combined command produces a practical enumeration baseline. The saved output should be included as evidence in the final submission. The assessment should record the exact output rather than inventing a fixed list of ports.

1.8 Service Analysis

For every discovered service, the analyst should ask three questions: What business or technical function does the service provide? Is that function required for the host to be publicly reachable? What security exposure is created by keeping the service open? A public training server may intentionally expose services for educational purposes, so a service being open does not automatically mean it is a production misconfiguration.

Service Type	Typical Purpose	Security Consideration	Public Necessity
HTTP	Web content or training pages	Application vulnerabilities, weak headers and outdated components	Only if web service is required
SSH	Secure remote administration	Credential attacks and exposed administrative interface	Usually not required for ordinary public users
FTP	File transfer	Credential/data exposure if poorly secured	Normally unnecessary for a public web host
DNS	Name resolution	Misconfiguration or unauthorized transfer	Required only when host provides DNS
Other TCP service	Application-specific function	Depends on implementation/version	Must be justified by business need

1.9 Threat-Actor Use of Enumeration

Enumeration reduces uncertainty for an attacker. A threat actor can use service names and versions to search vulnerability databases, select likely exploit techniques, identify administrative interfaces, infer the operating system, and prioritize services that commonly accept credentials. Enumeration can also guide later password attacks against exposed authentication services. The important security lesson is that information disclosure can increase the efficiency of subsequent attacks even when enumeration itself does not compromise the host.

1.10 Risk Assessment

Risk	Likelihood	Impact	Recommended Priority
Unnecessary public service	Medium	Medium-High	High

Outdated exposed service	High	High/Critical	Immediate
Administrative interface exposed to Internet	Medium–High	High	Immediate
Version/banner disclosure	High	Low–Medium	Medium
Unrestricted training service	Depends on intended purpose	Depends on data	Review against scope

1.11 Recommendations

- Expose only services that have a documented business requirement.
- Patch operating-system and application components regularly.
- Restrict administrative services using VPN, allowlists or other network controls where practical.
- Disable unnecessary services and close unused ports.
- Minimize unnecessary version/banner disclosure.
- Use strong authentication and MFA for administrative access where supported.
- Monitor logs for repeated connection attempts and abnormal authentication activity.
- Repeat enumeration after remediation to verify that the attack surface has actually decreased.

QUESTION 2 – METASPLOITABLE 2: 192.168.56.101

2.1 Lab Context

The supplied assessment identifies 192.168.56.101 as Metasploitable 2 in an isolated laboratory and requires comprehensive Nmap enumeration, including open ports, services, versions, operating-system information, service purpose, potential entry points, High/Medium/Low risk classification and explanation of how the results guide exploitation strategy. 穀filecite學turn3file0學L18-L26係

2.2 Discovery and Scanning Method

```
nmap -sn 192.168.56.101
nmap -sS 192.168.56.101
nmap -p- 192.168.56.101
nmap -sV -O 192.168.56.101
nmap -sC -sV 192.168.56.101
```

For the deliberately vulnerable laboratory machine, a full port scan is appropriate because the target is explicitly isolated for training. The tester should save each result and compare service versions against the known Metasploitable configuration.

2.3 Representative Metasploitable Service Inventory

Metasploitable 2 is intentionally vulnerable and commonly exposes numerous legacy services. The exact scan output should be taken from the student's VM because configuration changes or networking differences can affect the result. The following table is a representative assessment structure rather than a claim that every row will appear in every VM scan.

Common Port / Service	Purpose	Typical Risk in Metasploitable Lab	Reason
21 / FTP	File transfer	High	Legacy FTP configurations can expose weak authentication or vulnerable server software.
22 / SSH	Secure remote administration	Medium	Administrative access is sensitive; weak credentials or

			outdated implementations can increase risk.
23 / Telnet	Remote terminal access	High	Credentials and sessions are transmitted insecurely.
25 / SMTP	Mail transfer	Medium	Mail services may reveal system information or provide attack surface.
53 / DNS	Name resolution	Medium	Misconfiguration can disclose information or expose unnecessary functionality.
80 / HTTP	Web service	High	Legacy web applications may contain multiple vulnerabilities.
111 / RPCbind	RPC service mapping	High	Can reveal additional RPC services and increase attack surface.
139/445 / SMB	Windows/Unix file-sharing interoperability	High	File sharing can expose shares, credentials or legacy protocol weaknesses.
3306 / MySQL	Database service	High	Direct database exposure creates significant attack surface.
5432 / PostgreSQL	Database service	High	Direct database exposure can allow unauthorized access if authentication is weak.
8180 / Tomcat	Java web application server	High	Management/application interfaces can be sensitive.

2.4 Risk Categorization

Risk is assigned based on exposure, service sensitivity, likely weakness and potential consequence. In a deliberately vulnerable machine, High-risk labels are expected because the environment is intentionally designed to demonstrate weaknesses.

Risk Level	Typical Services	Assessment Rationale
High	Telnet, FTP, SMB, HTTP vulnerable apps, exposed databases, legacy RPC	Potentially direct entry points or significant information disclosure.
Medium	SSH, SMTP, DNS and other supporting services	Important attack surface but typically requires additional conditions or stronger controls.
Low	Non-sensitive informational services with no exploitable weakness identified	Limited impact when properly configured; still requires review.

2.5 How Enumeration Guides a Penetration Test

Enumeration allows the tester to create an attack-surface map. If Nmap identifies FTP, the tester can inspect the FTP banner, anonymous-access configuration and software version. If SMB is exposed, share and protocol configuration become relevant. If a database port is directly reachable, authentication and network segmentation should be reviewed. If HTTP exposes a legacy application, web-specific testing becomes a priority. The sequence is therefore: identify service → identify version/configuration → research relevant weakness → perform safe validation → document evidence → recommend remediation.

2.6 Recommended Lab Reporting

- Attach the Nmap normal-output file to the report.
- Create a port/service table with protocol, version and risk.
- Highlight services that are unnecessary even within the simulated production design.
- Map each high-risk service to a potential testing objective.
- Record screenshots of important scan results.

- After remediation, repeat the scan and compare the before/after attack surface.

QUESTION 3 – WINDOWS WORKSTATION: 192.168.56.102

3.1 Objective

The financial organization wants to assess a Windows workstation before connecting it to production. The question requires identification of active ports, network services, file-sharing protocols, remote-management services and OS information, followed by a least-privilege assessment, attack-surface analysis and hardening recommendations.

3.2 Nmap Enumeration

```
nmap -sn 192.168.56.102
nmap -sS -p- 192.168.56.102
nmap -sV -O 192.168.56.102
nmap -sC -sV 192.168.56.102
```

The full-port scan establishes the network attack surface. Service detection identifies applications associated with the open ports, while OS detection provides an estimate of the Windows platform characteristics.

3.3 Windows Services of Particular Interest

Port / Service	Typical Windows Function	Security Concern	Least-Privilege Question
135 / RPC	Windows RPC endpoint mapping	Exposes remote management surface	Is remote RPC required from the relevant network zones?
139 / NetBIOS	Legacy file/printer sharing	Information disclosure and legacy protocol risk	Can NetBIOS be disabled?
445 / SMB	Windows file/printer sharing	Lateral movement and credential attacks	Which hosts actually need SMB access?
3389 / RDP	Remote desktop	Brute-force and remote-access exposure	Is RDP required and restricted to administrators?
5985/5986 / WinRM	PowerShell/remote management	Remote administration exposure	Can access be restricted to management hosts?
80/443 / HTTP(S)	Web services	Application-specific exposure	Is a local web service necessary?

3.4 Least-Privilege Evaluation

Least privilege means the workstation should expose only the network services required for its business role. A workstation that does not function as a file server should not generally provide broad inbound SMB access. RDP and WinRM should be restricted to authorized management networks and accounts. Legacy NetBIOS functionality should be removed when not required. The assessment should distinguish between a service being enabled locally and that service being reachable from untrusted networks.

3.5 Attacker Use of Exposed Services

An attacker who reaches a Windows workstation can use service banners and protocol behavior to identify the platform and determine likely attack paths. SMB can provide information about host and share configuration and can become relevant to credential-based lateral movement. RDP provides a direct interactive access mechanism if credentials are compromised. WinRM can provide powerful remote-management capability when authorized credentials are abused. These risks make network-level restrictions and strong authentication essential.

3.6 Hardening Recommendations

- Apply current Windows security updates and firmware updates.
- Disable SMBv1 and other obsolete protocols where present.

- Restrict inbound SMB, RDP and WinRM using Windows Firewall and network segmentation.
- Use MFA for remote administrative access where supported.
- Limit local administrator privileges and use separate administrative accounts.
- Use strong, unique passwords and appropriate account lockout/rate controls.
- Enable endpoint detection and response and centralized Windows event logging.
- Disable unnecessary services and scheduled tasks.
- Use Network Level Authentication for RDP where applicable.
- Place administrative services behind a management network or VPN.

3.7 Pre-Production Acceptance Criteria

Control	Acceptance Test
Open ports	Every exposed port has a documented business owner and purpose.
Remote management	Only authorized management networks can reach RDP/WinRM.
File sharing	SMB access is restricted to required systems.
Patch level	Critical security updates are current.
Privileges	Users operate without unnecessary administrator rights.
Logging	Authentication and security events are centrally monitored.

QUESTION 4 – OWASP JUICE SHOP SERVER: 192.168.56.103

4.1 Objective

The supplied case identifies 192.168.56.103 as an OWASP Juice Shop Server and asks for host discovery, port scanning, service-version detection, OS fingerprinting and web-service identification. It also requires analysis of how exposed web and supporting services support the application, risks from administrative interfaces and supporting services, and recommendations to minimize exposure. 穀filecite學turn3file0學L37-L45傢

4.2 Enumeration Commands

```
nmap -sn 192.168.56.103
nmap -sS -p- 192.168.56.103
nmap -sV -O 192.168.56.103
nmap -sC -sV 192.168.56.103
whatweb http://192.168.56.103
curl -I http://192.168.56.103
```

4.3 Web-Service Identification

The tester should determine whether the server exposes HTTP or HTTPS, which application framework is being used, whether a reverse proxy is present, and whether additional ports expose application-management or database functionality. Juice Shop is intentionally vulnerable as an educational application, so vulnerability findings should be separated from infrastructure exposure findings.

4.4 Supporting-Service Risk

Exposure	Potential Role	Risk	Recommended Control
HTTP/HTTPS	Hosts Juice Shop application	High	Use HTTPS and restrict exposure to the required audience.

Administrative interface	Application/server management	High/Critical	Restrict to management network and require strong authentication.
Database port	Application data storage	High/Critical	Bind to localhost/private network and restrict firewall access.
SSH/RDP	Server administration	High	Limit to management network and use strong authentication.
Unnecessary service	Unrelated functionality	Medium-High	Disable and remove from attack surface.

4.5 Using Enumeration to Identify Web Risks

Service versions help identify potentially vulnerable dependencies. HTTP headers and technology fingerprints can reveal framework information. Port exposure can reveal database or administration interfaces that should not be Internet-accessible. Directory and endpoint discovery can then be performed within the authorized lab to map the application. The important principle is that infrastructure enumeration creates the map used by later web-application testing.

4.6 Recommendations

- Expose only the web ports required for the Juice Shop training environment.
- Restrict SSH and other administration services to trusted management hosts.
- Do not expose databases directly to untrusted networks.
- Use a reverse proxy or WAF where appropriate for a production architecture.
- Apply network segmentation between the web tier and data tier.
- Patch supporting operating-system and server components.
- Use HTTPS and secure cookie settings.
- Disable debugging and unnecessary administrative interfaces in production.
- Monitor access logs and unusual request patterns.
- Re-run Nmap after hardening and document the reduced attack surface.

QUESTION 5 – NETWORK GATEWAY: 192.168.56.1

5.1 Objective

The gateway is described as the primary connection between the internal laboratory network and external networks. The administrator suspects unnecessary management services are exposed. The question requires port scanning, service detection, OS fingerprinting and script-based enumeration, with specific attention to SSH, Telnet, SNMP, HTTP and HTTPS management interfaces. 穀filecite學turn3file0學L46-L55傢

5.2 Enumeration Commands

```
nmap -sn 192.168.56.1
nmap -sS -p- 192.168.56.1
nmap -sV -O 192.168.56.1
nmap -sC -sV 192.168.56.1
nmap --script banner,default 192.168.56.1
```

Where specific management scripts are appropriate, they should be selected carefully and run only against the authorized gateway. Avoid intrusive or configuration-changing scripts unless explicitly approved by the laboratory.

5.3 Management-Service Analysis

Service	Purpose	Security Implication	Recommended State
SSH	Secure administrative access	Strong control is required; exposed Internet-facing SSH increases attack surface.	Restrict to management network/VPN; disable if unnecessary.
Telnet	Legacy remote administration	Credentials/session data may be transmitted insecurely.	Disable.
SNMP	Monitoring/management	Weak community strings or excessive exposure can disclose information.	Use secure SNMPv3 where required and restrict sources.
HTTP management	Web administration	Unencrypted administrative sessions are unsafe.	Disable or redirect; do not expose externally.
HTTPS management	Encrypted administration	Safer than HTTP but still sensitive.	Restrict by IP/VPN and enforce strong authentication.

5.4 How Attackers Could Exploit Misconfiguration

An attacker first uses enumeration to identify management services and versions. A Telnet service may reveal a legacy administrative interface and insecure credential transport. An exposed SNMP service can disclose device and network information if configured weakly. SSH and HTTPS administration can become targets for credential attacks if they are reachable from untrusted networks. HTTP management can expose credentials or session data. Once administrative access is obtained, the gateway represents a high-value control point because it can influence routing, firewall rules, DNS, VPN configuration and other network-security functions.

5.5 Risk Matrix

Finding	Severity	Impact	Action
Telnet enabled	Critical/High	Credential interception and unauthorized administration	Disable immediately.
SNMPv1/v2 exposed broadly	High	Information disclosure and management risk	Restrict access; migrate to SNMPv3.
HTTP management exposed	High	Administrative traffic may be exposed	Disable HTTP; use restricted HTTPS.
SSH exposed to all networks	High	Credential/password attacks	Restrict to VPN/management subnet.
HTTPS management unrestricted	High	Privileged interface exposed	Apply allowlists, MFA and monitoring.

5.6 Gateway Hardening

- Disable Telnet and any unnecessary legacy management services.
- Restrict SSH and HTTPS management to a dedicated administration network or VPN.
- Use MFA for administrator access where supported.
- Use SNMPv3 with strong authentication/privacy if SNMP is required.
- Change default credentials and remove unused accounts.
- Apply firmware and security updates from trusted vendors.
- Use management-plane ACLs to limit source addresses.
- Enable centralized logging and alerting for administrative events.
- Back up configurations securely and protect backup files.

- Review firewall and routing rules under change control.
- Periodically scan the gateway from authorized internal and external vantage points.

INTEGRATED ENUMERATION METHODOLOGY

Phase 1 – Authorization and Scope

Before scanning, document the target IP/hostname, permitted tools, permitted time window and actions. This is especially important when a target is public or shared. The supplied assessment distinguishes a public training host from isolated laboratory systems, so the testing intensity should match the stated environment.

Phase 2 – Host Discovery

Use ping and Nmap host discovery to establish whether the target is alive. For local laboratory networks, a ping sweep can identify active systems when the scope contains multiple hosts.

```
nmap -sn 192.168.56.0/24
```

Phase 3 – Port Scanning

Perform a default scan first, followed by a full TCP scan when the scope permits. Port numbers create the first service inventory and help prioritize deeper enumeration.

```
nmap -sS <authorized-target>  
nmap -p- <authorized-target>
```

Phase 4 – Service Enumeration

Use service/version detection to associate open ports with applications and versions. This is critical because an open port without service context is less useful for risk analysis.

```
nmap -sV <authorized-target>
```

Phase 5 – OS Fingerprinting

OS fingerprinting helps determine the platform and can guide patch and configuration analysis. It should be treated as an estimate and confirmed with other evidence where possible.

```
sudo nmap -O <authorized-target>
```

Phase 6 – Script Enumeration

Default scripts can gather additional service information. Script selection should remain proportional to the assessment and authorized scope.

```
nmap -sC <authorized-target>
```

Phase 7 – Risk Analysis

A service becomes a security concern when its exposure, weakness and potential impact outweigh its legitimate business requirement. Risk should consider likelihood, exploitability, data sensitivity, privilege level and network reachability.

Phase 8 – Reporting and Retesting

The final report should connect evidence to conclusions. Each high-risk finding should include the observed port/service, why it is unnecessary or weak, potential consequence, remediation and retest result. A before-and-after comparison demonstrates whether the attack surface has actually improved.

COMPARATIVE ATTACK-SURFACE ANALYSIS

Target	Primary Enumeration Focus	Highest-Risk Areas	Key Hardening
scanme.nmap.org	Public host and service discovery	Unnecessary public services; outdated exposure	Minimize ports, patch, restrict admin access
192.168.56.101	Legacy Linux/Metasploitable services	FTP/Telnet/SMB/databases/legacy web	Disable legacy services; patch; segment
192.168.56.102	Windows file-sharing/remote management	SMB/RDP/WinRM	Firewall, least privilege, MFA, patching
192.168.56.103	Web application and supporting services	Web/admin/database exposure	Segmentation, HTTPS, restricted admin/data tiers
192.168.56.1	Network-management plane	Telnet/SNMP/HTTP/admin interfaces	Management ACLs, SSH/HTTPS, SNMPv3, MFA

COMMON NMAP COMMAND REFERENCE

Purpose	Command
Host discovery	<code>nmap -sn <target></code>
TCP SYN scan	<code>nmap -sS <target></code>
All TCP ports	<code>nmap -p- <target></code>
Service/version detection	<code>nmap -sV <target></code>
OS detection	<code>sudo nmap -O <target></code>
Default scripts	<code>nmap -sC <target></code>
Combined enumeration	<code>sudo nmap -sS -sV -O -sC <target></code>
Save output	<code>nmap -sV <target> -oN enumeration.txt</code>

FINAL CONCLUSION

Enumeration is the foundation of a network-security assessment because it converts an unknown network target into a structured attack-surface map. The five cases in this assessment deliberately span public training infrastructure, a vulnerable Linux machine, a Windows workstation, a web-application server and a network gateway. Across all five scenarios, the same principles apply: discover only authorized hosts, identify exposed ports, determine services and versions, understand the business purpose of each service, evaluate whether the exposure is justified, assess the consequences of compromise and recommend controls that reduce unnecessary exposure.

The most important security principle is least privilege at the network-service level. A host should expose only the services necessary for its role, and sensitive management services should be reachable only from trusted administration paths. Patching, network segmentation, strong authentication, secure management protocols, logging and continuous verification provide layered protection.

For submission quality, actual Nmap outputs should be captured from the specified environments and inserted alongside the analysis. The supplied assessment rubric gives weight to conceptual understanding, model/tool usage, analysis of results and documentation, with documentation requiring clear and structured reporting.

CODE OF CONDUCT / STUDENT DECLARATION

I K Nitheesh Kumar (192325090) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: K Nitheesh Kumar

Register Number: 192325090